API Security Risk Analysis

---

1. Project Overview

A report to identify the security vulnerabilities in a public API, analyse the risks and provide recommendations to improve security.

API Tested: JSON Placeholder (https://jsonplaceholder.typicode.com)

Tools Used:

- Postman
- Browser DevTools (Network Inspector)

---

2. Objectives

- Identify **insecure API endpoints** and exposed data
- Analyse **authentication and authorization** mechanisms
- Detect **missing rate limiting** or input validation vulnerabilities
- Explain risks in **simple business-friendly language**
- Recommend **remediation steps**

---

3. Methodology

3.1 **Endpoint Testing**: test all the public endpoints using Postman to retrieve data.
3.2 **Data Exposure Check**: to return JSON data for sensitive fields like email, phone, or address.
3.3 **Authentication & Authorization**: Check whether endpoints required API keys or user credentials. Test access to multiple user records to identify broken access control.
3.4 **Rate Limiting**: Send repeated requests to check if the API implements request limits.
3.5 **Input Validation**: Sent potentially malicious payloads to detect vulnerabilities such as XSS or injection attacks.
3.6 **Documentation**: Screenshots and findings were recorded for all tests.

4. Findings

Vulnerability	Risk Level	Description
No Authentication	Medium	API allows access to all endpoints without API keys.
Data Exposure	Low	Sensitive user data such as emails and phone numbers are visible to anyone.
Broken Access Control	Medium	Any user can access all other user data without restrictions.
No Rate Limiting	Medium	API allows unlimited requests in which it could lead to abuse or DDoS attacks.
Missing Input Validation	Medium	API accept potentially malicious input without sanitization.

---

5. Impact

Consequences of the vulnerabilities above:

- **Unauthorized access** to restricted resources
- **Leakage** of user information
- **System abuses** due to unlimited requests
- **Injection attacks** from unvalidated input

---

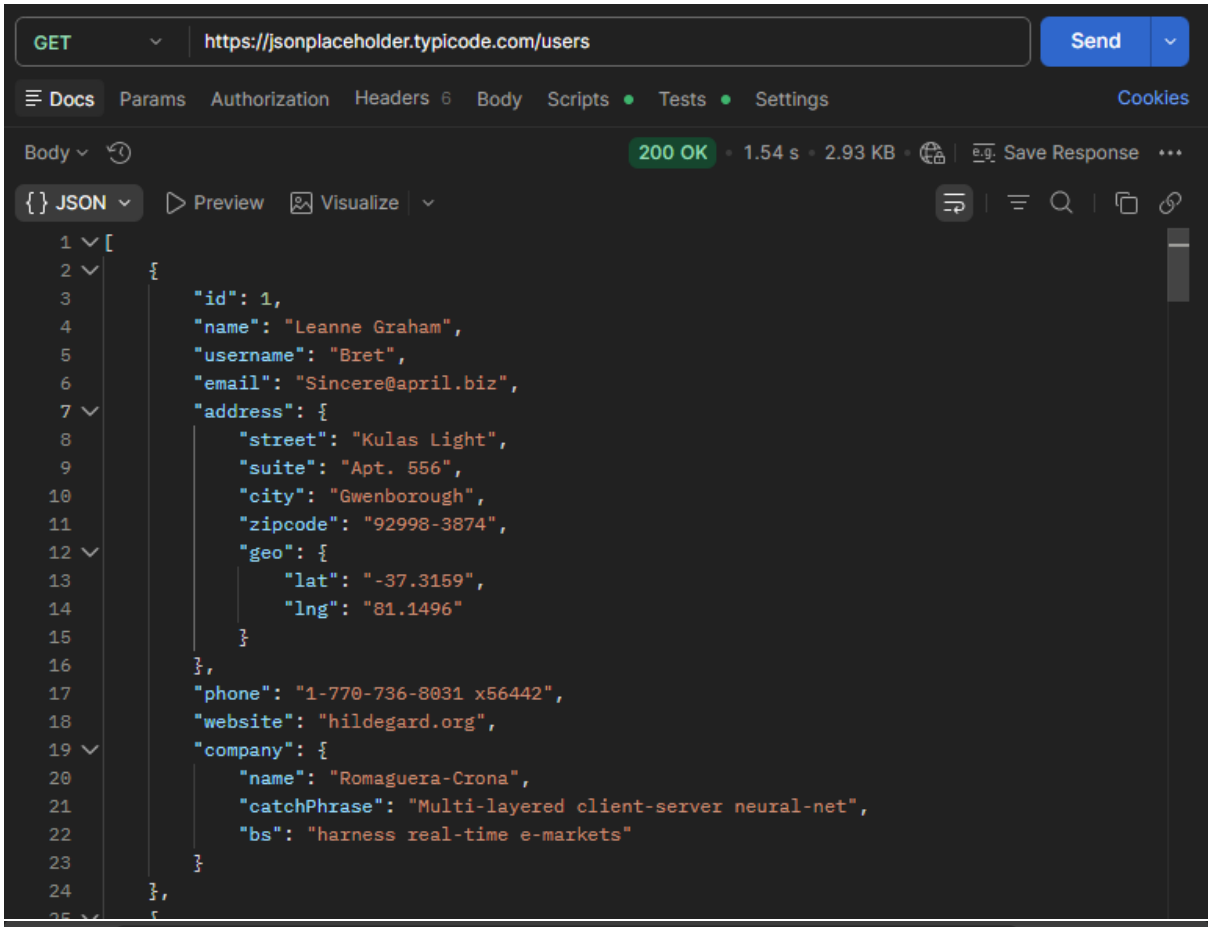
6. Recommendations

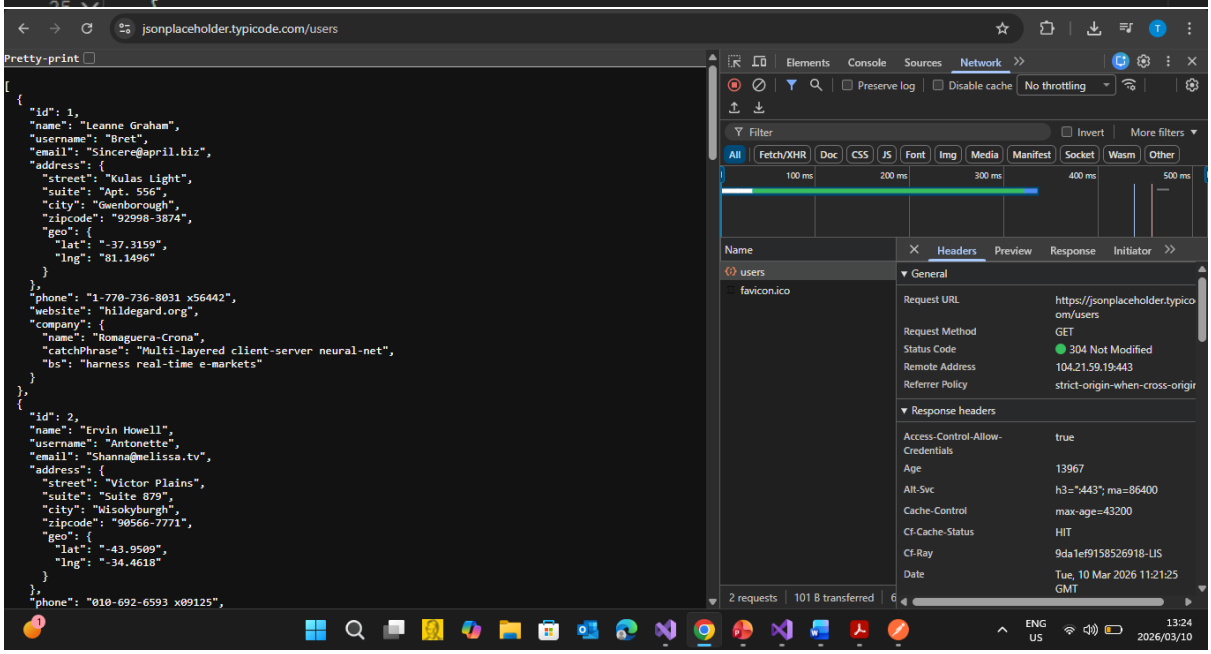
- **No Authentication**: Implement API keys for all endpoints.
- **Data Exposure**: Restrict sensitive fields so that only authorized users can access them.
- **Broken Access Control**: Implement proper access controls to restrict access per user roles.

- **No Rate Limiting**: Introduce rate limits to prevent DDoS attacks.
- **Missing Input Validation**: Validate all user inputs server-side.

---

7. Screenshots





TOKOLLO Sammy's Workspace

COLLECTIONS
- My Collection
  - GET Get data
  - POST Post data

GET https://jsonplaceholder.typicode.com/users

Send

Auth Type: No Auth

No Auth

This request does not use any authorization.

200 OK · 809 ms · 2.94 KB

GET https://jsonplaceholder.typicode.com/users/2

Send

Auth Type: No Auth

No Auth

This request does not use any authorization.

200 OK · 2.27 s · 1.4 KB


```
{
    "id": 2,
    "name": "Ervin Howell",
    "username": "Antonette",
    "email": "Shanna@melissa.tv",
    "address": {
        "street": "Victor Plains",
        "suite": "Suite 879",
        "city": "Wisokyburgh",
        "zipcode": "90566-7771",
        "geo": {
            "lat": "-43.9509",
            "lng": "-34.4618"
        }
    },
    "phone": "010-692-6593 x09125",
```


API Testing for Onboa...

that's currently open)

2. What would you like to test?

For example:

- Do you want to verify the response is correct?
- Check that it returns the right status code?
- Validate the data structure?
- Something else?

Once I understand what you're trying to accomplish, I can walk you through it step-by-step. We can add test scripts, run your collection, or set up automated testing—whatever works best for you!

What would be most helpful right now?

GET https://jsonplaceholder.typicode.com/users

Send

Auth Type: No Auth

No Auth

This request does not use any authorization.

200 OK · 1.26 s · 2.93 KB


```
[
    {
        "id": 1,
        "name": "Leanne Graham",
        "username": "Bret",
        "email": "Sincere@april.biz",
        "address": {
            "street": "Kulas Light",
            "suite": "Apt. 556",
            "city": "Gwenborough",
            "zipcode": "92998-3874",
            "geo": {
                "lat": "-37.3159",
                "lng": "81.1496"
```


API Testing for Onboa...

that's currently open)

2. What would you like to test?

For example:

- Do you want to verify the response is correct?
- Check that it returns the right status code?
- Validate the data structure?
- Something else?

Once I understand what you're trying to accomplish, I can walk you through it step-by-step. We can add test scripts, run your collection, or set up automated testing—whatever works best for you!

What would be most helpful right now?

TOKOLLO Sammy's Workspace

GET https://jsonplaceholder.typicode.com/users

200 OK · 1.54 s · 2.93 KB


```
[
    {
        "id": 1,
        "name": "Leanne Graham",
        "username": "Bret",
        "email": "Sincere@april.biz",
        "address": {
            "street": "Kulas Light",
            "suite": "Apt. 556",
            "city": "Gwenborough",
            "zipcode": "92998-3874",
            "geo": {
                "lat": "-37.3159",
                "lng": "81.1496"
            }
        },
        "phone": "1-770-736-8031 x56442",
        "website": "hildegard.org",
        "company": {
            "name": "Romaguera-Crona",
            "catchPhrase": "Multi-layered client-server neural-net",
            "bs": "harness real-time e-markets"
        }
    },
    {
```


POST https://jsonplaceholder.typicode.com/users

201 Created · 354 ms · 1.28 KB


```
{
    "name": "<script>alert('hacked')</script>",
    "email": "Tokollo@gmail.com",
    "id": 11
}
```